

Segurança de End Points



estão de Inventário Hardware e Softwares

Por mais que possa parecer simples, o gerenciamento de todo o inventário de hardware e software que a organização possui é importantíssimo para o processo de gestão da segurança da informação e segurança cibernética. Isto porque, para se garantir o controle e a proteção dos ativos tecnológicos é preciso em primeiro lugar conhecê-los!

Por meio do gerenciamento de inventário de hardware e software as equipes de TI, passam a ter o conhecimento e controle dos ativos tecnológicos tanto na questão de hardware (computadores, servidores, roteadores, switches, etc.) quanto na questão de software (sistemas de informação, aplicativos desktop, aplicativos de comunicação, etc.) o que permite, por exemplo: (a) saber se o parque tecnológico encontra-se adequado com relação a poder de processamento, memória e armazenamento para atender as necessidades e demandas impostas pelas estratégias da organização; (b) controlar a aquisição e licenciamento de softwares de acordo com as necessidades; © monitorar questões relacionadas a pirataria de software ou roubo interno de peças de hardware; (d) ter um controle sobre as configurações realizadas em desktops e servidores e assim por diante.

Realizar o gerenciamento de inventário de hardware e software de uma organização, significa realizar uma lista contendo todos os equipamentos de TI e todas as ferramentas de TI utilizados na organização. Como resultado, os gestores e as equipes de TI conseguem visualizar os principais ativos e ferramentas.

Cabe ressaltar que neste inventário irá conter além dos dispositivos computacionais tais como computadores e servidores e respectivamente os programas (softwares) utilizados na organização, também deverão constar: (a) licenças de uso dos programas; (b) dispositivos mobiles tais como: smartphones, netbooks, notebooks, tablets e qualquer outro; © objetos pertencentes a TI e, quaisquer outros itens utilizados pela TI.

Mas, por que inventariar a TI? Bem, uma das principais vantagens em realizar o gerenciamento do inventário de hardware e softwares está em manter sempre uma lista atualizada do parque tecnológico da organização, a fim de: (a) detectar e prevenir futuros problemas relacionados à incompatibilidade de recursos computacionais versus novas tecnologias; (b) prevenir e corrigir de forma pró ativa, problemas relacionados a configurações; © conformidade e auditoria perante fabricantes ou desenvolvedores de softwares com relação a licenciamento de uso e pirataria de software; (d) auxiliar na tomada de decisões com relação a comparação de melhores soluções tecnológicas através de estudos relacionando custo versus benefício por produtividade e redução de custos, dentre outros.

Atualmente existem diversas soluções para o gerenciamento de inventário de hardware e software, algumas delas requerem a compra ou licenciamento de uso, outras por sua vez são totalmente open sources. Porém, não necessariamente a equipe de TI precisa de uma solução específica. No geral, organizações de pequeno ou médio porte optam em fazer esse controle por meio de planilhas, não que esteja errado. Mas, com certeza dá um trabalho maior se comparado com soluções tecnológicas automatizadas que capturam todas as informações necessárias de forma automática que uma lista de inventário precisa.

Gestão de Vulnerabilidade

Acredito que você já percebeu até aqui, que a preocupação das equipes de segurança são muitas. Uma das mais importantes é a gestão de vulnerabilidades. Ou seja, o gerenciamento e análise dos pontos fracos presentes nos ativos de TI e que possam ser explorados por uma ou mais ameaças.

Podemos compreender a gestão de vulnerabilidades como um processo que irá identificar, monitorar, analisar e mitigar fraquezas presentes nos ativos de TI e com isso impossibilitar que qualquer tipo de ameaça explore essa fraqueza e traga como consequência um evento ou incidente não desejável que por sua vez proporcione um dado ou perda qualquer para a organização.

O processo de gestão de vulnerabilidades é complexo e envolve a elaboração de uma série de estratégias que visam proteger os ativos de TI contra riscos à segurança

da informação e à segurança cibernética. Temos que entender que realizar a gestão de vulnerabilidades, significa eliminar ou mitigar falhas ou pontos fracos antes que eles causem algum dano ou prejuízo à organização.

No geral, a gestão de vulnerabilidade requer do profissional de TI habilidades e conhecimentos relacionados a redes, dispositivos computacionais, sistemas operacionais, sistemas/aplicativos entre outros. Como exemplo de vulnerabilidades podemos citar: (a) bugs de desenvolvimento e programação; (b) erros de configurações; © falta de atualizações em sistemas; (d) ausência de mecanismos de proteção em dados; etc.

Lembre-se o objetivo da gestão de vulnerabilidades é o de detectar e corrigir falhas, ou seja, vulnerabilidades que possam comprometer os ativos de TI e, todo seu objetivo deve sempre estar com o foco na melhoria contínua não só dos ativos envolvidos, mas também na segurança da informação e segurança cibernética.

Por fim, para uma boa gestão de vulnerabilidades adote como conjuntos de ações: (a) identificação das vulnerabilidades; (b) análise das vulnerabilidades; © priorização; (d) aplicação das medidas preventivas e de redução de impacto; (e) tratamento (mitigação ou eliminação) das vulnerabilidades e, (f) monitoramento e melhoria contínua;

Atualmente, existem diversos sistemas que possibilitam a gestão de vulnerabilidades, tais como o NESSUS do desenvolvedor Tenable e o Greenbone Openvas da desenvolvedora Greenbone.

Vírus, Spam, Trojans, Backdoors e outros...

Atualmente, com a transformação digital, todas as organizações estão sempre preocupadas e em alerta com relação a ameaças virtuais. Principalmente as ameaças apresentadas como códigos maliciosos – vírus, trojans, backdoors, worms, malwares, ransomwares, etc.

As atenções voltadas à proteção dos ativos de TI com relação a códigos maliciosos, se justificam. Isto porque, os códigos maliciosos podem causar sérios danos à organização em diversos aspectos tais como: operacional, financeiro, marca e

reputação dentre outros. Por esse motivo, implementar medidas de proteção contra esse tipo de ameaça torna-se imperativo por parte das equipes de segurança da informação e principalmente de segurança cibernética, até mesmo porque grande parte desses códigos maliciosos estão presentes na Internet.

Entre o universo de códigos maliciosos que ameaçam os ativos de TI de uma organização os que ganham maior destaque por conta do grau de destruição e periculosidade são: (a) rootkit – trata-se de um pacote de programas maliciosos, que substituem os arquivos binários (programas compilados) por um kit de programas que mantém uma porta aberta sem que verdadeiro root (administrador do unix) perceba. Com a porta aberta o invasor pode voltar a qualquer momento e utilizar os privilégios do root ou do usuário do serviço que ele tenha utilizado, para realizar absolutamente qualquer ação dentro do computador, inclusive roubar, alterar ou destruir qualquer informação. Os rootkit são extremamente difíceis de serem detectados, e infectam o sistema sem que o usuário perceba nada. É difícil garantir a completa remoção dos rootkit de um sistema, esses programas são especializados em enganar as ferramentas de segurança para ficarem ocultos. A forma mais confiável de reaver seu computador é formatar o disco e reinstalar todo o sistema; (b) trojans/backdoors – trata-se de uma possível fonte de vazamento de informações sensíveis. São os canais secretos de comunicação, ou seja, canais que dos quais os usuários ignoram a existência. Estes canais são chamados de porta de manutenção ou backdoor, e são comumente utilizados por Trojans para comunicar-se com seu controlador, ou até mesmo fornecer acesso à máquina infectada.

São considerados backdoor os programas ou partes de códigos escondidos em outros programas, que permitem que um invasor entre ou retorne a um computador comprometido por uma porta dos fundos, sem ter que passar pelo processo normal de autenticação. Nos primórdios da computação, os próprios programadores deixavam alguns backdoor em seus sistemas e os chamavam de “ganchos de manutenção”; © ransomware – trata-se de um código malicioso que tem como função realizar o “sequestro de dados” através da criptografia dos dados contidos em um sistema computacional ou sistema de banco de dados. No geral os criminosos cibernéticos utilizam o ransomware como uma forma de extorquir valores monetários, através da solicitação de “resgates”, igualmente a um sequestro de uma pessoa, por exemplo. Esses resgates são solicitados por meio de pagamento através de moedas digitais, conhecidas como criptomoedas que por padrão são dificilmente rastreáveis.

Ou seja, não se consegue identificar a fonte recebedora do pagamento. Atualmente o grau de periculosidade é considerado uma ameaça extremamente perigosa e potencialmente danosa, causando em alguns casos até a falência da organização caso seus dados não sejam mais recuperados. Como exemplos de ransomwares que causaram mais danos a organizações de diversas partes do mundo, destacam-se: WannaCry, TeslaCrypt, NotPetya, Revil, Samsam e Sodinokibi.

Ameaças Persistentes Avançadas.

Considerada uma evolução dos tipos de ameaças, as APTs ou ameaças persistentes avançadas é um termo utilizado para descrever uma campanha no qual um ou mais criminosos cibernéticos se juntam para realizar um ataque a uma organização e estabelecer sua presença dentro do ambiente de TI desta organização por longos períodos, a fim de se obter o máximo possível de dados e informações altamente confidenciais.

No geral os alvos de um APT são grandes organizações privadas ou governamentais e, incluem: (a) intrusão total a infraestrutura de TI; (b) roubo de dados e informações importantes, valiosas ou confidenciais; © sabotagem de infraestruturas e/ou sistemas/aplicativos de TI; (d) paralisação de serviços e recursos computacionais.

Já com relação os motivos que levam a esse tipo de ataque, destacam-se: (a) motivos ideológicos tais como: ideologia política ou sociais; (b) vingança; © sabotagem industrial; (d) ciber terrorismo, dentre outros.

É importante ressaltar que em comparação com outros tipos de ameaças, as ameaças persistentes avançadas são bem mais complexas, executadas e coordenadas de forma manual e minuciosa e geralmente visam a infiltração e controle total de toda a infraestrutura de TI da organização de forma obscura com muita dificuldade de ser detectada por parte das equipes de segurança da informação e segurança cibernética.

Por fim, um ataque do tipo APT possui três estágios, sendo o primeiro a infiltração onde os criminosos invadem a infraestrutura de TI; o segundo à expansão, onde os

criminosos se expandem dentro da infraestrutura de TI e, o terceiro a extração, onde os criminosos capturam dados e informações de sistemas e banco de dados.

EDR e XDR

EDR acrônimo de Endpoint Detection e Response e XDR acrônimo de Extended Detection e Response, são considerados atualmente a evolução dos tradicionais sistemas de antivírus que eram instalados em computadores e servidores para proteger contra códigos maliciosos. Isto porque, são desenvolvidos com base em tecnologias de inteligência artificial e aprendizagem de máquinas que permitem detectar, identificar, prevenir, mitigar e responder aos mais vários tipos de ameaças cibernéticas tais como: trojans, backdoors, rootkits, ransomwares, malwares, incluindo até ameaças do tipo APT, se tornando assim uma poderosa ferramenta de proteção utilizada pelas equipes de segurança da informação e segurança cibernética.

As soluções EDR e XDR possuem um investimento relativamente alto devido a toda a tecnologia desenvolvida. Esse investimento se torna justificado pelo simples fato de que as soluções EDR e XDR possuem mecanismos de proteção que podem ser implementados em diferentes infraestruturas (local ou nuvem) e, proteger um universo de dispositivos computacionais, sistemas, aplicativos, tecnologias, serviços e recursos de rede, dados, informações etc. Além de apresentar soluções que permitam: (a) caçar ameaças – mesmo aquelas que ainda não foram identificadas ou classificadas; (b) realizar o rollback de dados e informações para o caso de sequestro de dados; © proteção a diversos tipos de sistemas operacionais etc.

Por fim as soluções EDR e XDR auxiliam as equipes de segurança em suas operações diárias realizadas no SOC e, principalmente a superar obstáculos que limitam a sua capacidade de identificar e detectar ameaças mais sofisticadas e maliciosas e, tudo isso acontece porque as soluções EDR e XDR possibilitam: (a) a visibilidade por completo de toda a infraestrutura de TI, independentemente de onde ela esteja – local ou nuvem; (b) classificação de maneira automática e inteligente de todos os eventos de segurança e por fim © a priorização de ações e medidas para eliminar ou conter ameaças e códigos maliciosos mais evoluídos.

Gestão de Backup e Recuperação de Dados

A gestão de backup e recuperação de dados é algo importantíssimo para a organização. Isto porque, permite a ela ter uma total segurança e controle sobre seus dados em caso de um evento ou incidente não desejável com relação a perda de dados.

Toda a equipe de segurança da informação, segurança cibernética e as demais equipes de TI, devem ter em mente três pontos importantes com relação às tecnologias da informação. São eles: (1) qualquer sistema computacional está suscetível a falha; (2) qualquer usuário pode cometer erros e, (3) problemas aparecem quando menos se espera. Diante desses três pontos apresentados, a organização pode sofrer um ou todos eles a qualquer momento e, sendo assim, ter um sistema de gestão de backups e recuperação de dados torna-se uma medida necessária.

O backup e a recuperação de dados ou também denominado de “recovery” é são dois processos contidos na gestão de backup e recuperação de dados. Sendo que o primeiro “backup” tem como objetivo realizar a salvaguarda dos dados para o caso de uma perda acidental ou não. Já o segundo “recovery” tem como objetivo a recuperação dos dados salvaguardados. É importante ressaltar que o processo de backup requer que os dados sejam copiados de forma íntegra (sem alterações e, em seu estado atual) e armazenados em um local seguro com os devidos mecanismos de proteção tais como: senha e criptografia, para que quando necessário possam ser restaurados ao local de origem no mesmo estado em que se encontravam antes do incidente.

A gestão de backup e recuperação de dados é um processo pertencente e importante de um plano de recuperação de desastres e, por isso precisa sempre ser verificado e avaliado pelas equipes de TI ou segurança da informação, para garantir que em primeiro lugar o processo de salvaguarda dos dados está ocorrendo de forma correta e em segundo lugar que quando necessário o processo de recuperação de dados também ocorra de forma correta.

Atualmente, existem diversas soluções para realizar a gestão de backup e recuperação de dados, algumas delas são por meio de aquisição ou licença de uso e outras no formato open source, podendo os dados serem armazenados em infraestruturas de nuvem, por exemplo. Como exemplo de soluções corporativas, destacam-se:

VERITAS, ACRONIS, AWS BACKUP dentre outras. Já no modelo open source destaca-se: BACULA SERVER BACKUP.

Seja qual for a solução escolhida o processo de backup sempre poderá ser realizado das seguintes formas: (a) backup completo – onde os dados são copiados de forma completa, ou seja é feita uma cópia de tudo; (b) backup incremental – onde há somente a cópia dos dados que sofreram alguma modificação após o último backup realizado e por fim © backup diferencial – no qual a cópia dos dados é bem similar o modelo incremental, porém com um detalhe os dados são copiados com base no último backup completo realizado.

Conteúdo Bônus

Complemente seu conhecimento sobre Gestão de Vulnerabilidades

- Tebable – Gerenciamento de Vulnerabilidades: Tudo o que você precisa saber. Disponível no site Tenable.
- Livro: Contagem Regressiva até Zero Day: Stuxnet e o lançamento da primeira arma digital do mundo/kim Zetter – Rio de Janeiro: Brasport, 2017.

Referência Bibliográfica

CISCO. “**Como funcionam as redes privadas virtuais.**” 13 de outubro de 2008. (6 de novembro de 2019) Disponível em:

<https://www.cisco.com/c/pt_br/support/docs/security-vpn/ipsec-negotiation-ike-protocols/14106-how-vpn-works.html>.

FONTES, E. **Praticando a segurança da informação**. Brasport, 2008.

FREIRE, Alexandre. **Sistemas de Firewall e Defesa de Perímetros**. Portal Módulo Security, 2004.

Guide to Intrusion Detection and Prevention Systems (IDPS). Disponível em: <<http://csrc.nist.gov/publications/nistpubs/800-94/SP800-94.pdf>>.

HARRIS, Shon. **CISSP All-in-one, 3. ed.**: Mc Graw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento**. Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação**. Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

Microsoft “TechNect: protocolos de encapsulamento de VPN.” 2011. (6 de novembro de 2019) [http://technet.microsoft.com/en-us/library/cc771298\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771298(WS.10).aspx)

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes. 4 ed.** São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

TANENBAUM, Andrew. S. **Redes de Computadores. 4ª ed.** Rio de Janeiro: Editora Campus (Elsevier), 2011.

